

- 2026 전자정부 정보보호 컨퍼런스

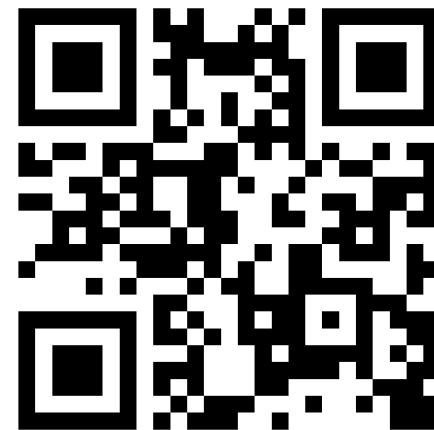
AI Runtime Security

AI 보안의 사각지대를 없애다

eBPF/LSM 기반 런타임 보안

 남재현

 단국대학교 컴퓨터공학과 교수



March 2026
BoanLab @ DKU

Speaker

남재현



단국대학교

- 컴퓨터공학과 교수
- SW중심대학사업단 오픈소스SW센터 센터장
- 단국대 자체 사설 클라우드(SOLID Cloud) 운영

SRI International

- Stanford Research Institute
- 2015년부터 2019년까지 방문 연구원으로 활동
- SDN/NFV, 컨테이너 보안 연구 등 수행

AccuKnox (클라우드/AI 보안)

- 공동창업자 겸 Lead of R&D 로 근무

KubeArmor

- Cloud-Native Runtime Enforcement System
- 2021년 CNCF Sandbox 프로젝트로 공식 합류
- 100만 회 이상의 누적 다운로드 돌파
- 2천개 이상의 GitHub Star

목차

01

Intro AI 환경의 구조적 전환과 보안 패러다임 변화

AI 도입과 클라우드 전환에 따른 경계형 보안의 한계를 분석하고, 왜 지금 새로운 보안 접근이 필요한지 문제 제기

02

Risks AI 시스템화로 등장한 새로운 보안 리스크

AI가 단순 도구를 넘어 '시스템'으로 동작할 때 발생하는 데이터 유출, 자원 탈취, 오판 등 기존 IT와 다른 새로운 위협 식별

03

Analysis AI 공격은 어디에서 발생하는가

데이터·모델·입력 단계의 공격 유형을 분석하고, 모든 피해가 최종적으로 '실행 단계(Runtime)'에서 발생함을 규명

04

Strategy 실행 단계(Runtime) 대응 전략: eBPF/LSM

커널 레벨의 가시성(eBPF)과 강제 차단(LSM) 기술을 결합한 실시간 런타임 보안 아키텍처 및 대응 방안 제시

AI 환경의 구조적 전환과 보안 패러다임 변화

핵심 이슈: 공공기관의 AI 도입이 PoC(개념 증명) 단계를 넘어 실제 운영 환경으로 전환되면서,
기존 경계형 보안 모델로는 대응할 수 없는 새로운 구조적 한계가 발생하고 있습니다.

왜 지금 공공기관에서 AI 보안인가?

단순 실험(PoC) 단계를 넘어 실제 운영 환경에 AI가 결합되면서 보안의 패러다임이 변화하고 있습니다.



01

PoC를 넘어 운영 단계로 전환

개념 검증(PoC)에서 실제 업무 시스템으로 확대되면서 더 이상 실험이 아닌 **핵심 운영 인프라**로 자리잡았습니다. 장애 발생 시 파급력이 전사적으로 확대됩니다.



02

공공 클라우드 전환 가속

온프레미스 환경에서 클라우드 SaaS, API 중심 구조로 빠르게 이동하면서 **물리적 보안 경계가 모호**해지고, 외부 서비스와의 연결 접점이 기하급수적으로 증가했습니다.



03

전통적 경계형 보안의 한계

경계 중심(Perimeter Security) 모델은 동적 워크로드, 마이크로 서비스 환경에서 **내부 행위에 대한 가시성과 통제력**이 부족하여 지능형 위협 탐지에 한계가 있습니다.



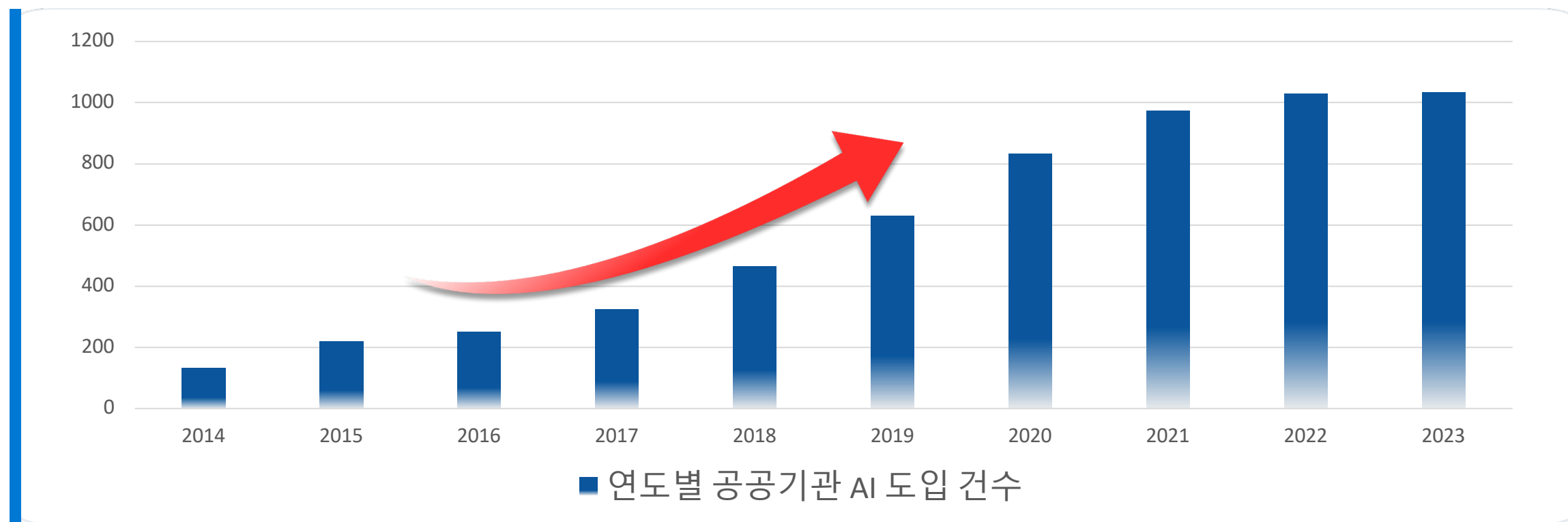
04

운영 리스크 확대

민감 데이터 접근과 자동화된 의사결정이 결합되면서 **오동작, 유출, 권한 오남용**의 파급력이 증가했습니다. 입력값에 따라 실행 결과가 달라지는 비결정적 특성이 위험을 가중시킵니다.

공공부문 AI 도입의 구조적 전환

공공기관의 AI 활용은 더 이상 선택이 아닌 필수가 되었습니다.
개념 검증(PoC)을 넘어 실제 운영 환경에 본격적으로 적용되고 있습니다.



공공부문 AI 도입의 구조적 전환

공공기관의 AI 활용은 더 이상 선택이 아닌 필수가 되었습니다.
개념 검증(PoC)을 넘어 실제 운영 환경에 본격적으로 적용되고 있습니다.



ADOPTION RATE

60%+

최근 10년간 공공기관 도입률

전체 공공기관의 과반수 이상이 이미 AI 관련 시스템 및 서비스를 도입하여 운영 중입니다. 이는 단순 시범 사업 단계를 넘어섰음을 의미합니다.



CONTRACT
S

5,800+

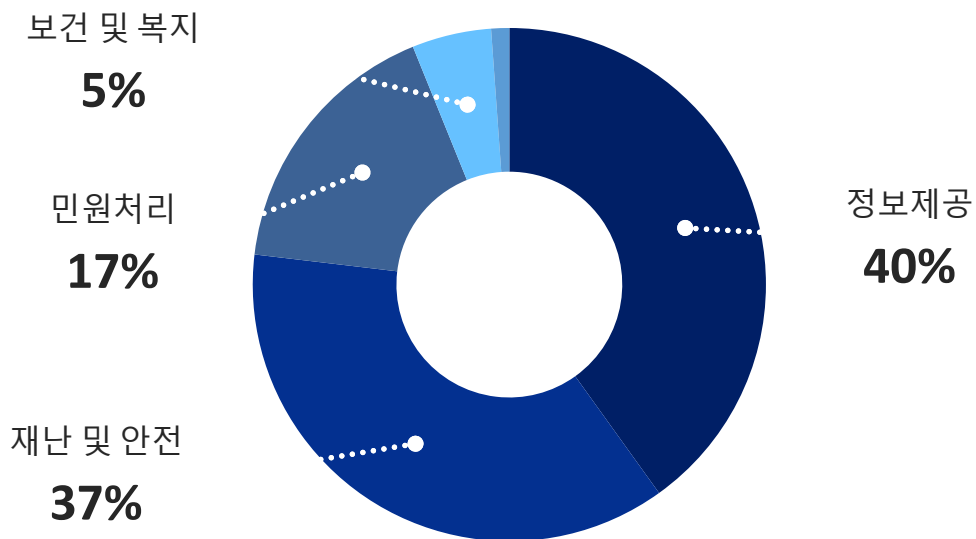
누적 AI 도입·계약 건수

대규모 언어 모델(LLM), 지능형 CCTV, 챗봇 등 다양한 분야에서 5,800건 이상의 계약이 체결되어 공공 서비스에 AI가 깊숙이 침투했습니다.

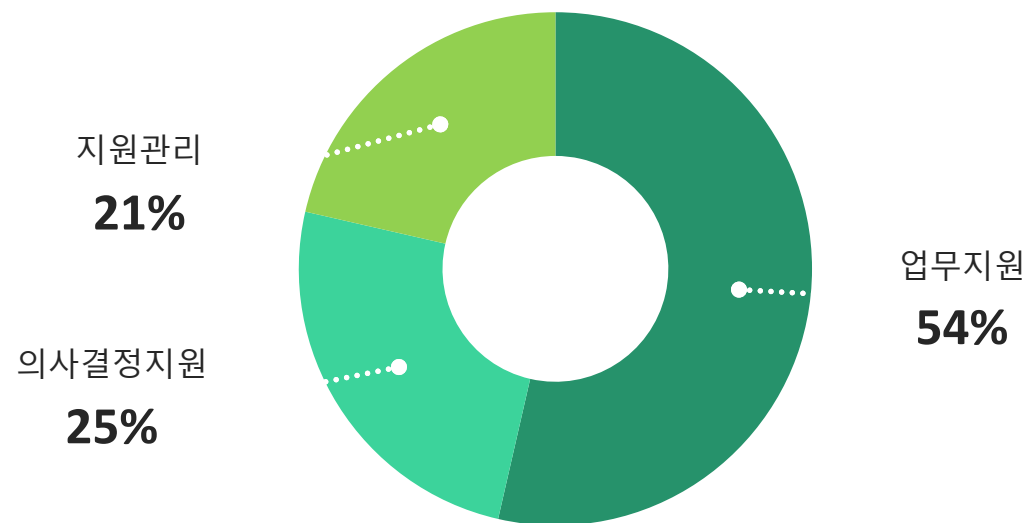
PoC를 넘어 운영으로의 확산

AI는 단순한 도구를 넘어 실제 행정 업무와 대민 서비스의 핵심 운영 인프라로 자리 잡고 있습니다.

대민 서비스 계약 건수



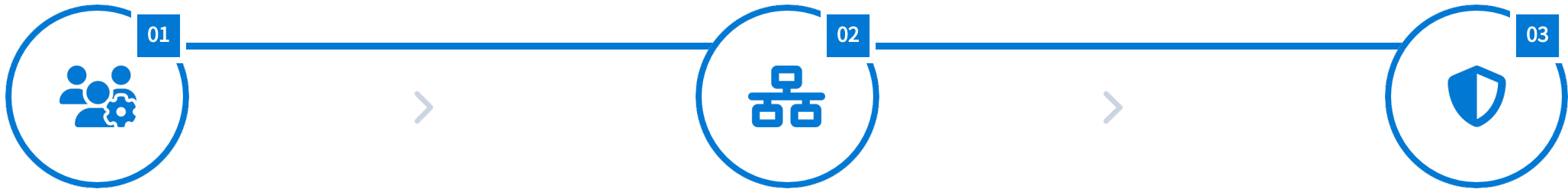
업무 효율화 계약 건수



PoC를 넘어 운영으로의 확산

AI는 단순한 도구를 넘어 실제 행정 업무와 대민 서비스의 핵심 운영 인프라로 자리 잡고 있습니다.

2030년 세계 수준 AI 강국 도약을 목표!



대민 서비스 고도화

민원 응대 · 챗봇
단순 안내를 넘어 복잡한 민원 처리를 자동화하고, 24시간 실시간 응대 체계 구축

시스템 결합

모델 · 에이전트 연동
AI 모델이 내부 DB 및 레거시 시스템과 직접 연동되어 실질적인 업무 프로세스 수행

신뢰 · 안전 프레임워크

국가 차원 제도 정비
AI 신뢰성 확보를 위한 법제화 및 안전 가이드라인 수립, 운영 단계 보안 요구사항 강화

💡 운영 결합의 의미: 보안 사고 파급력 확대

실제 운영 시스템과의 결합은 보안 사고 발생 시 **사용자 피해, 예산 손실, 기관 평판 하락**으로 즉시 이어진다는 것을 의미합니다. 더 이상 샌드박스 내부의 실험이 아닙니다.

AI 활용에 따른 시스템 구조 변화

구조의 변화는 곧 보안 가정의 변화를 의미합니다. 정적 경계에서 동적 워크로드로의 전환을 이해해야 합니다.

기존 시스템

On-Premise / Monolithic

자원 할당

정적 자원 할당

GPU/연산 자원의 유연한 확장 어려움

배포 방식

주기적 중단 배포

모델 업데이트 시 서비스 다운타임 필요

외부 연계

제한적 연계 (폐쇄망)

외부 데이터 및 API 접근 차단 중심



VS

클라우드 AI 환경

Cloud Native / AI Service-Oriented

자원 할당

동적 GPU 할당 (Auto-scaling)

트래픽에 따라 연산 자원 즉시 확장/축소

배포 방식

자동화된 지속적 배포 (CI/CD)

중단 없는 모델 업데이트 및 MLOps 파이프라인

외부 연계

API 기반 유연한 연계

외부 LLM, 데이터 소스와의 실시간 통신 필수



Paradigm Shift in Security

경계 내부의 신뢰(Implicit Trust)는 더 이상 유효하지 않습니다. 이제 워크로드 단위의 최소 권한 원칙과 실행 가시성이 보안의 핵심입니다.

기존 보안의 한계: **경계형** 모델의 문제

정적인 경계 방어 모델은 동적이고 경계가 모호한 AI/클라우드 환경에서 가시성을 잃고 있습니다.



전통 경계형 보안

Traditional Perimeter Security

- **데이터센터 중심의 고정 경계**
명확한 내부/외부 경계를 가정하고 방화벽 등 주변부 방어에 집중
- **사후 탐지 및 서명 기반**
이미 알려진 공격 패턴(Signature) 매칭이나 에이전트 기반 사후 로그 수집 의존
- **정적 가시성의 한계**
"무엇이 실행될지"를 미리 가정하는 정적 분석 방식은 런타임 변동성에 취약



클라우드 · AI 환경

Cloud Native & AI Workloads

- ✓ **경계가 모호한 환경**
멀티클라우드, SaaS, API, 컨테이너 환경에서는 물리적 경계가 사실상 소멸
- ✓ **동적 워크로드와 마이크로서비스**
수시로 생성/삭제되는 Pod와 컨테이너 환경에서는 IP 기반 통제가 불가능
- ✓ **커널 수준 가시성 필요**
eBPF 등을 통해 실행 시점(Runtime)의 시스템 내부 동작(행위)을 실시간으로 추적해야 함



AI의 비결정성(Non-determinism)은 런타임에서만 통제 가능합니다.

AI 도입으로 인한 새로운 보안 리스크

핵심 이슈: AI가 단순한 보조 도구를 넘어 자율적인 판단과 실행을 수행하는 '시스템'으로 진화하면서, 기존 IT 환경에서는 경험하지 못한 데이터 오염, 모델 탈취, 프롬프트 인젝션 등 새로운 유형의 보안 위협이 현실화되고 있습니다.

AI 도입으로 인한 새로운 보안 리스크

AI가 다양한 시스템과 연결되고 자동으로 판단·실행을 수행하게 되면서, 기존 IT 시스템에서는 없던 새로운 유형의 보안 위협이 나타나고 있습니다.



대량 데이터 유출 위험

대량·민감 데이터에 대한 모델/에이전트의 접근 권한이 확대되면서, 한 번의 침해로 방대한 데이터가 유출되거나 프라이버시가 침해될 가능성이 증가합니다.



AI 오판에 따른 즉시 장애

자동화된 의사결정의 오류가 실제 운영 시스템에 즉시 반영되어, 업무 중단이나 오인 판단으로 인한 물리적/금전적 피해를 야기할 수 있습니다.



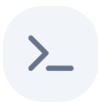
키·토큰 탈취 및 권한 오남용

API 키나 서비스 계정 토큰이 탈취될 경우, 공격자는 AI 시스템이 가진 광범위한 시스템 접근 권한을 그대로 획득하여 치명적인 피해를 입힐 수 있습니다.



인프라 자원 탈취 및 과금 폭탄

고가의 GPU 자원을 노린 크립토마이닝 공격이나, 의도적인 대량 추론 요청을 통해 클라우드 비용을 폭증시키는 자원 고갈 공격(DoS)이 발생할 수 있습니다.



프롬프트 인젝션 및 모델 공격

학습 데이터 오염, 모델 추출, 프롬프트 인젝션 등 AI 고유의 취약점을 악용하여 모델의 안전 정책을 우회하거나 악성 행위를 유도하는 공격이 등장했습니다.



Systemization Risk

AI가 '시스템'이 되면
보안 위협의 범위와 파급력이
기하급수적으로 확대됩니다.

실제 사례로 본 시스템화 리스크

AI의 '시스템화'는 단순한 도구 도입을 넘어, 새로운 보안 위협을 야기하고 있습니다.

데이터 유출 우려



中 AI '딥시크' 개인정보 유출 논란...
韓 공공기관·은행 줄줄이 접속 '차단'

"개인정보가 중국 서버로 전송될 가능성이 제기되면서 공공기관과 금융권이 해당 생성형 AI 서비스 접속을 차단하고 있다."

에이전트 권한 악용



AI가 사람대신 PC 조작해 업무... 주요 IT기업 '오픈클로 금지령'

"사내에서 AI 에이전트가 내부 시스템과 데이터를 직접 조작할 수 있다는 점이 보안 위협으로 지적되며 사용이 금지됐다."

행정망 보안



챗GPT에 입력되는 서울 행정 정보...
보안 우려에 '사업자 믿는다'?

"폐쇄망이 아닌 외부 인터넷망 기반 AI 도입으로 인해 공무원이 입력한 행정 정보가 외부 서버로 전송될 수 있다는 보안 우려가 커지고 있다."

Common Factor: The Connection



이들의 공통 분모는 '외부 서비스·에이전트와 내부 자산의 직접 결합'입니다.
연결된 순간, 내부와 외부의 경계가 사라지고 기존 통제 방식이 무력화됩니다.

AI 공격은 어디에서 발생하는가

단계별 위협 분석: 데이터, 모델, 입력 단계의 공격은 모두 다르지만, 실제 시스템의 피해는 결국 **실행(Runtime)** 단계에서 발생한다는 공통적인 패턴을 가지고 있습니다.

데이터 단계 & 모델 단계 공격

학습 데이터와 모델 구조를 노리는 공격은 배포 전 단계에서 은밀하게 이루어집니다.



데이터 단계

학습 데이터를
오염시키는 공격

☹ 데이터 오염

라벨을 변조하거나 특정 그룹에
편향된 데이터를 주입하여 모델
의 판단 기준 자체를 왜곡

🔒 백도어(Backdoor)

특정 트리거 입력 시에만 오동작
하도록 악성 패턴을 학습시켜 평
소에는 정상처럼 위장

👤 개인정보 삽입

학습 데이터에 민감 정보를 의도
적으로 포함시켜 모델이 이를 암
기하고 추론 시 유출하도록 유도



모델 단계

모델 파라미터와
구조를 노리는 공격

🔗 모델 역공학

API 응답 분석을 통해 모델 구조
를 복제하거나 학습 데이터의 일
부를 추정하여 지적 재산권 침해

⚡ 적대적 예제

사람은 인식 못하는 미세 노이즈
를 추가하여 모델의 오분류를 유
도 (이미지/음성 인식 회피)

⚙ 파라미터 변조

저장된 모델 파일이나 체크포인
트의 가중치를 직접 수정하여 모
델의 무결성을 훼손

! Key Insight: 공격의 '씨앗'은 학습·구조 단계에서 심어지지만, 실제 **피해는 실행(Runtime) 시점에서 결과로 드러납니다.**

입력 단계 공격 (Inference Input Phase)

모델의 답변을 넘어 시스템의 실행 흐름을 왜곡하는 행위 기반 공격입니다.



Policy Bypass

Jailbreak (탈옥)

안전 정책과 가드레일을 우회하여 모델이 금지된 답변을 생성하도록 유도합니다.

→ 모델 안전장치 무력화



Command Injection

프롬프트 인젝션

시스템 프롬프트를 무시하게 하고 공격자가 원하는 내부 정보 접근이나 역할 변경을 강제합니다.

→ 내부 데이터 접근 권한 획득



Knowledge Poisoning

RAG 문서 주입

검색 기반 생성(RAG) 시스템이 참조하는 문서에 악성 정보를 삽입하여 잘못된 답변을 유도합니다.

→ 신뢰할 수 없는 정보 확산



Memory Manipulation

컨텍스트 오염

대화 히스토리를 조작하거나 이전 대화 맥락을 왜곡하여 모델의 판단 흐름을 변경합니다.

→ 시스템 역할 및 목적 변질



입력 단계의 조작은 단순한 텍스트 변조가 아닙니다.

실제 시스템 호출(Function Call) 흐름을 바꾸어 실행 행위를 변조하는 것이 핵심 위험입니다.

실행 단계 공격 (Runtime Phase)

시스템 행위를 악용하여 실질적인 피해를 발생시키는 가장 위험한 공격 단계입니다.



External Call

API/외부 서비스 호출 악용

모델 응답이 실제 명령 실행으로 연결되어 파일 삭제나 권한 변경을 수행합니다.

→ 자동화 시스템 직접 타격



RCE

시스템 명령 실행

내부 API를 무단으로 호출하거나 셸 명령어를 실행하여 시스템을 장악합니다.

→ 운영체제 수준 제어권 획득



Resource Abuse

자원 탈취 및 과금

GPU를 무단으로 사용하여 크립토마이닝을 하거나 대량 추론 요청을 유발합니다.

→ 비용 폭탄 및 서비스 거부



Privilege Escalation

키·토큰 탈취 및 권한 상승

환경 변수에 접근하여 서비스 계정 키를 탈취하고 컨테이너 권한을 확장합니다.

→ 광범위한 시스템 접근 권한 확보



데이터, 모델, 입력 단계의 모든 공격은 최종적으로 실행 단계(Runtime)에서 실체화되며, 실제 피해는 이 시점에 발생합니다.

왜 AI 보안은 '실행 단계(Runtime)'가 핵심인가

AI 공격은 코드나 설정을 바꾸지 않고, 실행 중인 '행위(Behavior)'를 바꿉니다.

01



AI 시스템의 본질적 비결정성

AI는 동일한 코드와 모델이라도
입력(프롬프트, 컨텍스트)에 따라
전혀 다른 실행 경로를 동적으로
생성합니다.

02



기존 정적 보안의 구조적 한계

소스 코드 스캔이나 서명 기반
보안은 "**무엇이 실행될지**"를
사전에 가정하지만, AI의 행위는 실행
전까지 알 수 없습니다.

03



유일한 관찰 지점: 커널(Kernel)

실제 시스템 콜, 파일 접근,
네트워크 연결이 일어나는
커널 레벨에서만 조작된 행위의
실체를 포착할 수 있습니다.

💡 따라서 AI 보안은 실행 시점(Runtime)에서만 실체를 포착하고 방어할 수 있습니다.

실행 단계(Runtime) 대응 전략: eBPF와 LSM

핵심 솔루션: 커널 수준에서 모든 행위를 관찰하는 eBPF와 이를 정책 기반으로 즉시 차단하는 LSM 기술을 통합하여, AI의 예측 불가능한 런타임 공격에 실시간으로 대응하는 보안 전략을 제시합니다.

eBPF | 관찰·탐지 (Observe & Detect)

커널 레벨에서 시스템의 모든 행위를 실시간으로 투명하게 관찰하는 기술입니다.

How eBPF Works

애플리케이션 수정 없이
운영체제 커널에서 직접 관찰

USER SPACE



AI Apps & Containers

System Calls

KERNEL SPACE



eBPF Program Running

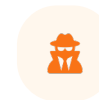
hooking:
kprobe, tracepoint, ...

- ✓ No Code Changes
- ✓ Low Overhead



행위 추적 (Visibility)

프로세스 실행(exec), 파일 열기(open),
네트워크 연결(connect) 등 모든 시스템
콜을 추적하여 누가 무엇을 했는지
기록합니다.



민감 정보 접근 탐지

환경 변수(Environment Variables),
비밀 키 파일, 토큰 저장소에 대한 비인가
프로세스의 접근 시도를 실시간으로
감지합니다.



네트워크 이상 징후 식별

DNS 쿼리 및 소켓 연결을 분석하여 학습
데이터 유출이나 C&C 서버와의 통신 등 비
정상적인 외부 전송을 식별합니다.



GPU 자원 오남용 감지

비정상적인 GPU 메모리 할당이나
고부하 연산 패턴을 분석하여 크립토마이
닝(Cryptomining)이나 자원 탈취 시도를
탐지합니다.

LSM | 정책·차단 (Policy & Enforcement)

커널 수준에서 프로세스의 행위를 사전에 검사하고 정책 기반으로 즉시 차단하는 보안 기술입니다.

How LSM Works

실행 전 검사(Hook)를 통해 허용되지 않은 행위 원천 차단

USER SPACE



Blocked Action

Permission Check

KERNEL SPACE



LSM Policy
Hooks Enforcement

SELinux / AppArmor
BPF-LSM

- 🔒 Least Privilege
- 🚫 Pre-Execution Block



사전 검사 및 차단

프로세스가 파일에 접근하거나 실행하려 할 때, 실제 동작이 일어날 수 있는지 권한을 먼저 검사하여 거부합니다.



SELinux/AppArmor 정책 적용

운영체제 수준의 강력한 강제적 접근 제어 (MAC) 모델을 적용하여 AI 컨테이너의 권한 범위를 엄격하게 제한합니다.



세밀한 리소스 제어

파일 읽기/쓰기 권한뿐만 아니라 네트워크 소켓 생성, 프로세스 간 통신(IPC) 등 시스템 자원을 세밀하게 제어합니다.

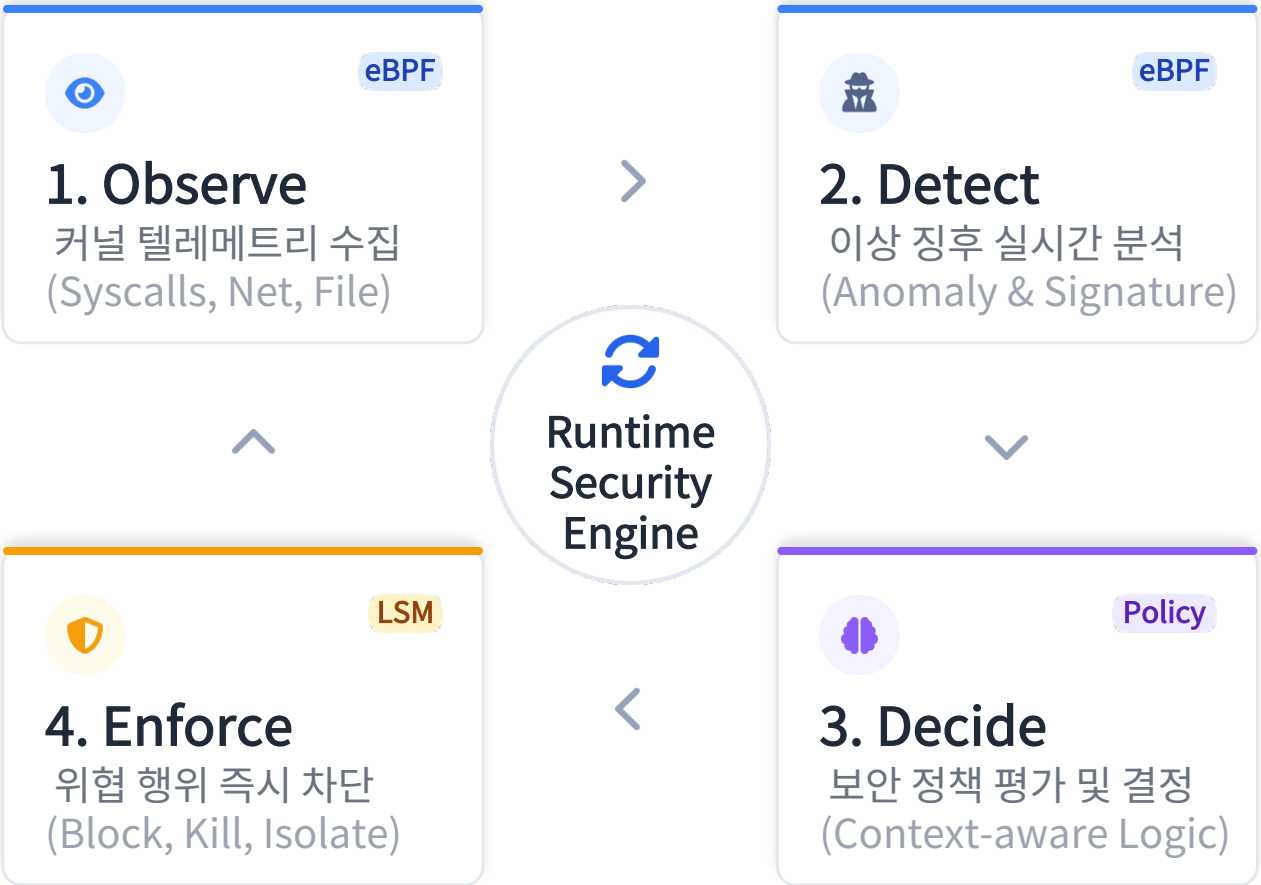


동적 정책 집행 (BPF-LSM)

eBPF의 탐지 결과와 연동하여, 정적인 정책뿐만 아니라 실시간 상황에 맞는 동적인 보안 정책을 즉시 적용합니다.

eBPF + LSM 통합: 관찰↔차단 페루프

관찰(Observe)에서 차단(Enforce)까지 자동화된 보안 사이클을 구축하여 공격 시간을 최소화합니다.



⚡ 실시간 대응 (Real-time Response)

탐지와 차단 사이의 지연 시간(Latency)을 'Zero'에 가깝게 줄여, 공격자가 시스템을 장악하기 전에 무력화합니다.

🔗 환경 일관성 (Consistency)

커널 레벨에서 동작하므로 VM, 컨테이너, 서버리스 등 모든 인프라에 동일한 보안 정책을 적용할 수 있습니다.

APPLIES
TO:



Containers



Kubernetes



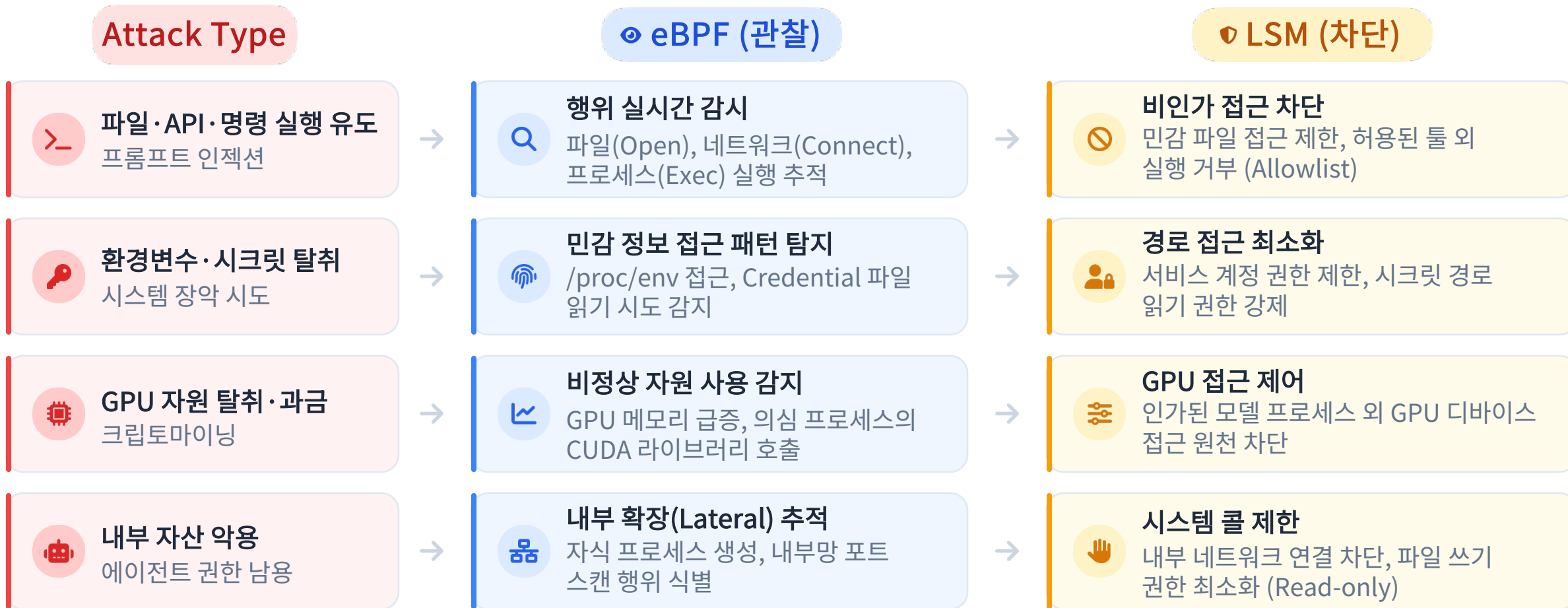
GPU
Nodes



Multi-
Cloud

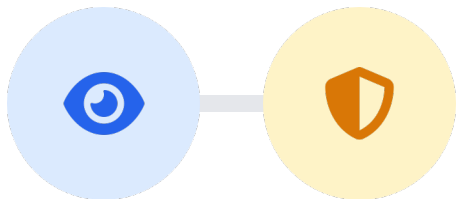
AI 공격 ↔ 런타임 대응 기술 매핑

eBPF로 보고(Observe), LSM으로 막는(Enforce) 일관된 대응 패턴



i 결론: 공격 유형이 무엇이든, 실행 단계의 행위(Runtime Behavior)를 제어하면 피해를 사전에 방지할 수 있습니다.

Secure Your AI at Runtime



Runtime Visibility + Real-time Enforcement

The Foundation of AI Security

보이지 않는 것을 **보게** 하고,
예측 불가능한 것을 **통제** 하십시오.

eBPF makes it Visible.
LSM makes it Controlled.

☰ If you need...



최소 권한 정책 적용 (Least Privilege)

모델 프로세스가 필요로 하는 파일/네트워크만 허용



시크릿 및 환경변수 관리 강화

비인가 프로세스의 Credential 접근 원천 차단



GPU 접근 제어 및 모니터링

인가된 워크로드 외 GPU 디바이스 접근 제한



고위험 행위 실시간 차단

Reverse Shell, 비인가 외부 통신 등 이상 행위 즉시 Kill



감사 로깅 (Audit Logging)

eBPF 기반의 상세한 런타임 행위 기록 보관

▶▶ Immediate Next Steps



KubeArmor

Install

Open Source K8s Security



ModelArmor

Install

Open Source AI Security